



LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING



MLflow CVE-2026-64849 SSRF Exploitation Daily Priority

CVE / Vulnerability Threat Intelligence Report

Classification	TLP:CLEAR
Published	2026-08-21
Version	1.0
Author	Lost Boys Cyber
Report Type	CVE / Vulnerability Threat Intelligence Report

TLP:CLEAR | Lost Boys Cyber | MLflow CVE-2026-64849 SSRF Exploitation Daily Priority - CVE / Vulnerability Threat Intelligence Report

Published: 2026-08-21 | TLP:CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. Executive Summary
2. Vulnerability Metadata
3. Source Review & Confidence
4. Vulnerability Details
5. Attack Scenarios
6. Threat Landscape & Exploitation Status
7. Affected Products and Exposure
8. Mitigation and Workarounds
9. Detection Engineering
 - 9.1. Detection Logic Summary
 - 9.2. Sigma / Detection Rule
 - 9.3. Hunt Query
10. Threat Hunting
 - 10.1. Hunt Hypothesis
 - 10.2. Hunt Query
11. MITRE ATT&CK Mapping
12. Validation / Lab Testing
13. Recommended Actions Summary
14. References

MLflow CVE-2026-64849 SSRF Exploitation Daily Priority

1. Executive Summary

MLflow CVE-2026-64849 SSRF Exploitation Daily Priority is prioritized today because public exploitation status and remediation deadlines make the exposed service a near-term defender concern. The issue affects MLflow tracking/model registry webhook delivery; organizations should treat internet-reachable or partner-reachable deployments as urgent until patched and reviewed.

The assessment is intentionally conservative: exploitation is tracked from CISA KEV/public reporting, while environment-specific impact depends on deployment architecture, authentication exposure, compensating controls, and log retention. Defenders should patch first, then hunt for pre-patch access patterns.

2. Vulnerability Metadata

Field	Value
CVE	CVE-2026-64849
Product / Component	MLflow tracking/model registry webhook delivery
Weakness	Unauthenticated full-read server-side request forgery through webhook URL validation/redirect behavior
Severity	High/Critical; see vendor and CVE records
Affected Versions	MLflow versions before the fixed 3.15.0 release according to public reporting
Fixed Versions	MLflow 3.15.0 or later
Disclosure / KEV Context	CISA KEV and public reporting reviewed on 2026-08-21
Exploitation Status	CISA KEV lists the flaw as exploited; public reporting describes cloud metadata and internal-service read exposure.

3. Source Review & Confidence

Source	Contribution	Confidence
CISA Known Exploited Vulnerabilities	Confirms exploitation-driven prioritization and remediation urgency	High
Vendor / CNA advisory	Product scope, fixed-version guidance, and vulnerability mechanics	High
Reputable security reporting	Defender context, exposed-service impact, and exploitation notes	Medium

The report uses at least three public references where available. The report does not assert victim counts, actor attribution, or private indicators unless those details appear in the cited sources.

4. Vulnerability Details

The vulnerable MLflow webhook path can be abused to make the server fetch attacker-controlled or internal URLs. In cloud deployments, SSRF can expose metadata-service credentials; in enterprise ML environments it can reveal internal services, model registry data, or credentials reachable from the MLflow host.

5. Attack Scenarios

- Exposed MLflow instance receives webhook test requests that redirect toward metadata or internal IP ranges.
- Stolen cloud role credentials are used to enumerate object storage, model artifacts, or secrets.
- Internal-only MLflow deployments are abused after VPN/SSO compromise to pivot into engineering infrastructure.

6. Threat Landscape & Exploitation Status

Public KEV inclusion means defenders should assume exploitation is operationally relevant rather than theoretical. Priority should be based on exposure and business criticality: externally reachable systems, systems with privileged integrations, and systems storing credentials or session tokens should move first.

7. Affected Products and Exposure

Exposure Pattern	Why It Matters
Internet-facing deployment	Enables unauthenticated or low-friction discovery, probing, and exploitation attempts.
Partner/VPN reachable deployment	Still reachable from compromised third parties, contractor endpoints, or abused valid accounts.
Privileged integration host	Successful compromise may expose credentials, internal services, or administrative data paths.
Patched and segmented deployment	Lower residual risk, but still requires post-patch log review for attempted access.

8. Mitigation and Workarounds

Priority	Owner	Action
Critical	Platform owner	Upgrade to the vendor-fixed version and confirm the vulnerable component is no longer exposed.
High	Network/security engineering	Restrict management/API/service ports to trusted administration networks.
High	Detection engineering	Search application, reverse-proxy, EDR, and identity logs for exploit-shaped requests and suspicious child processes.
Medium	IR lead	Preserve pre-patch logs and capture endpoint triage on high-value systems.

9. Detection Engineering

9.1. Detection Logic Summary

Signal	Telemetry Source	Analytic Goal
Unexpected service child process	EDR process telemetry	Identify code execution after service interaction.
Unusual inbound requests to vulnerable endpoint/service	Web/reverse-proxy/network logs	Surface scanning or exploit delivery attempts.

New outbound connection from service host	EDR/network telemetry	Detect staging, callback, metadata access, or payload retrieval.
---	-----------------------	--

9.2. Sigma / Detection Rule

```

title: Suspicious Vulnerable Service Child Process - MLflow tracking/model registry webhook delivery
id: lbc-mlflow-cve-2026-64849-ssrf-exploitation-daily-priority-proc
status: experimental
description: Detects suspicious interpreter or shell child processes spawned by a vulnerable service host after exploitation.
logsource:
  product: windows
  category: process_creation
detection:
  selection_child:
    Image|endswith:
      - '\cmd.exe'
      - '\powershell.exe'
      - '\pwsh.exe'
      - '\wscript.exe'
      - '\cscript.exe'
      - '\bash.exe'
  filter_admin:
    CommandLine|contains:
      - 'known-good-maintenance-marker'
  condition: selection_child and not filter_admin
fields:
  - Image
  - ParentImage
  - CommandLine
  - User
falsepositives:
  - Administrative scripts; tune by service account and maintenance window.
level: high

```

9.3. Hunt Query

```

// Hunt service-host execution and outbound network activity around CVE-2026-64849
let lookback = 14d;
let suspiciousChildren =
dynamic(['cmd.exe', 'powershell.exe', 'pwsh.exe', 'wscript.exe', 'cscript.exe', 'bash', 'sh', 'python.exe']);
DeviceProcessEvents
| where Timestamp > ago(lookback)
| where FileName in~ (suspiciousChildren)
| where InitiatingProcessFileName has_any
('trueconf', 'mlflow', 'vpxd', 'tomcat', 'java', 'python', 'nginx', 'httpd', 'w3wp')
| project Timestamp, DeviceName, FileName, ProcessCommandLine, InitiatingProcessFileName,
InitiatingProcessCommandLine, AccountName
| order by Timestamp desc

```

10. Threat Hunting

10.1. Hunt Hypothesis

An attacker attempted exploitation before the service was patched and either spawned an interpreter, reached a sensitive internal resource, or generated abnormal outbound traffic from the application host.

10.2. Hunt Query

```

DeviceNetworkEvents
| where Timestamp > ago(14d)
| where InitiatingProcessFileName has_any
('trueconf', 'mlflow', 'vpxd', 'tomcat', 'java', 'python', 'nginx', 'httpd', 'w3wp')
| summarize FirstSeen=min(Timestamp), LastSeen=max(Timestamp), Connections=count(),
RemoteIPs=dcount(RemoteIP) by DeviceName, InitiatingProcessFileName, RemoteUrl, RemotePort
| where Connections > 5 or RemotePort in (80,443,8080,8081,8443)

```

| order by Connections desc

11. MITRE ATT&CK Mapping

Technique	Name	Evidence / Rationale
T1190	Exploit Public-Facing Application	Vulnerable service exposure is the expected initial access path.
T1059	Command and Scripting Interpreter	Post-exploitation command execution is a key hunt signal where exploit impact reaches code execution or service misuse.
T1041	Exfiltration Over C2 Channel	Outbound callbacks or metadata reads should be reviewed after compromise.

12. Validation / Lab Testing

No exploit reproduction was performed in this automated daily run. Validation completed: source review, KEV/CVE-style metadata normalization, render QA, and defensive query construction. Operators should validate detections against local telemetry before production blocking.

13. Recommended Actions Summary

Priority	Owner	Action
Critical	Vulnerability management	Confirm every affected asset is patched or isolated within 24 hours.
High	SOC	Run the provided KQL hunts across the prior 14 days and escalate systems with suspicious child processes or callbacks.
Medium	Asset owner	Document exposure path, compensating controls, and business owner acceptance for any delayed remediation.

14. References

- [1] CISA KEV Catalog — <https://www.cisa.gov/known-exploited-vulnerabilities-catalog>
- [2] BleepingComputer MLflow SSRF exploitation report — <https://www.bleepingcomputer.com/news/security/cisa-warns-of-hackers-exploiting-critical-mlflow-vulnerability/>
- [3] Suriq MLflow SSRF technical summary — <https://suriq.io/blog/mlflow-ssrf-cve-2026-64849-cloud-metadata>
- [4] MLflow project security/advisories — <https://github.com/mlflow/mlflow/security/advisories>